COMP4127/COMP7850

Information Security

Blockchain

Reading: Bashir, Mastering Blockchain : distributed ledger technology, decentralization, and smart contracts explained, Packt, 2018

Outline

- Blockchain
  - Principles
  - Features
- Bitcoin as an example
- Application
- Other consensus protocols

一致的.

A false impression 印象

- Blockchain is only about bitcoin
- Bitcoin is a financial tools/scam 诈骗
- Bitcoin is issued by hackers
- Bitcoin is untraceable
- Bitcoin is insecure because it is untraceable
- Bitcoin is best for money laundry 洗钱.
- If you want to use blockchain technology, you need to invest money on server

img from coindesk

~~Bitcoin~~ Blockchain at a glance

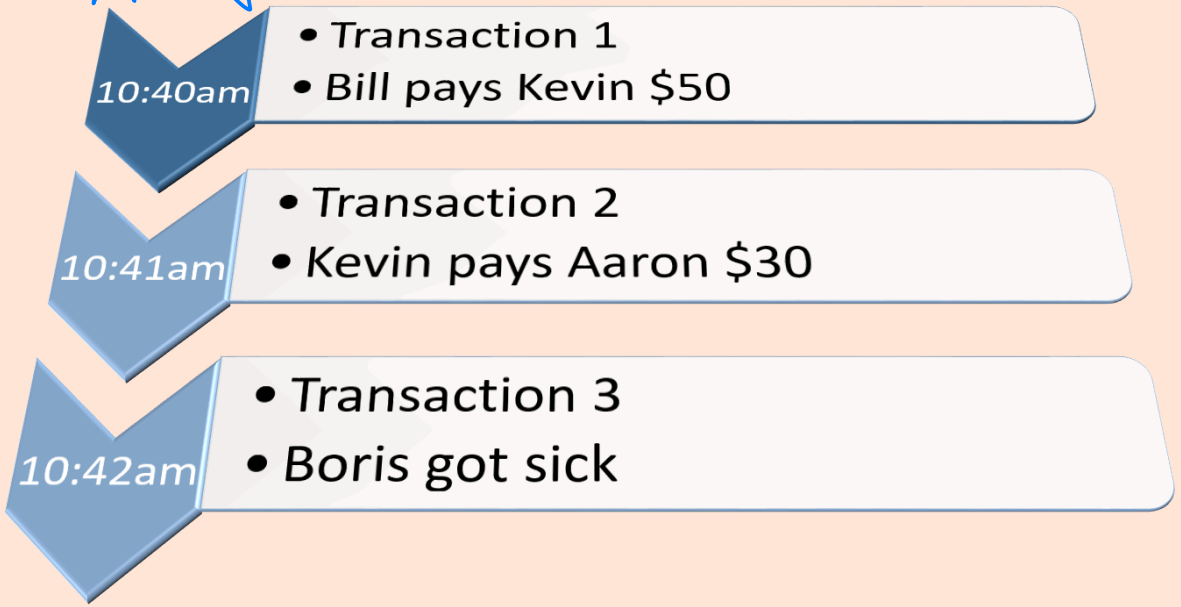
Blockchain is a technology rather than an application. This technology consists of multiple disciplines including crypto, distributed networks, database. Blockchain provides a secure *distributed ledger* system so that transaction can only be appended, but not removed or modified.

what is Block chain

分类帐簿

Can not take away

→ if take away → insecure



Security requirement of Ledger 帳簿

Ledger system is an important component in accounting, banking, or any database. Take banking system as an example, consider:

- A transaction is missing.
- The identity of the transaction is modified.
- The order of transaction is changed.
- A transaction has been injected.
- The system down.

How current ledgers are maintained?

- synchronized between banks - regulated by law
- centralized - conspiracy theory 阴謀论.

Important Properties of Blockchain

Refer to Bashir, the key properties of blockchain are:

- **Peer-to-Peer**: No central controller in the network, all participants talk to each other directly.
- **Distributed ledger**: A ledger (records of transactions) are spread across the network and each peer is holding a copy of the complete ledger.
- **Cryptographically secure**: It refers to that each transaction has the properties of non-repudiation, data integrity, data origin authentication(^) and the ledger itself will be able to be appended.
- **Append-only**: Transaction can only be added to the ledger in *time-ordered sequential order*.
- **Updateable via consensus**: No central authority is in control of updating the ledger. Any update (append) is done only after a consensus of all peers.

Benefits of blockchain

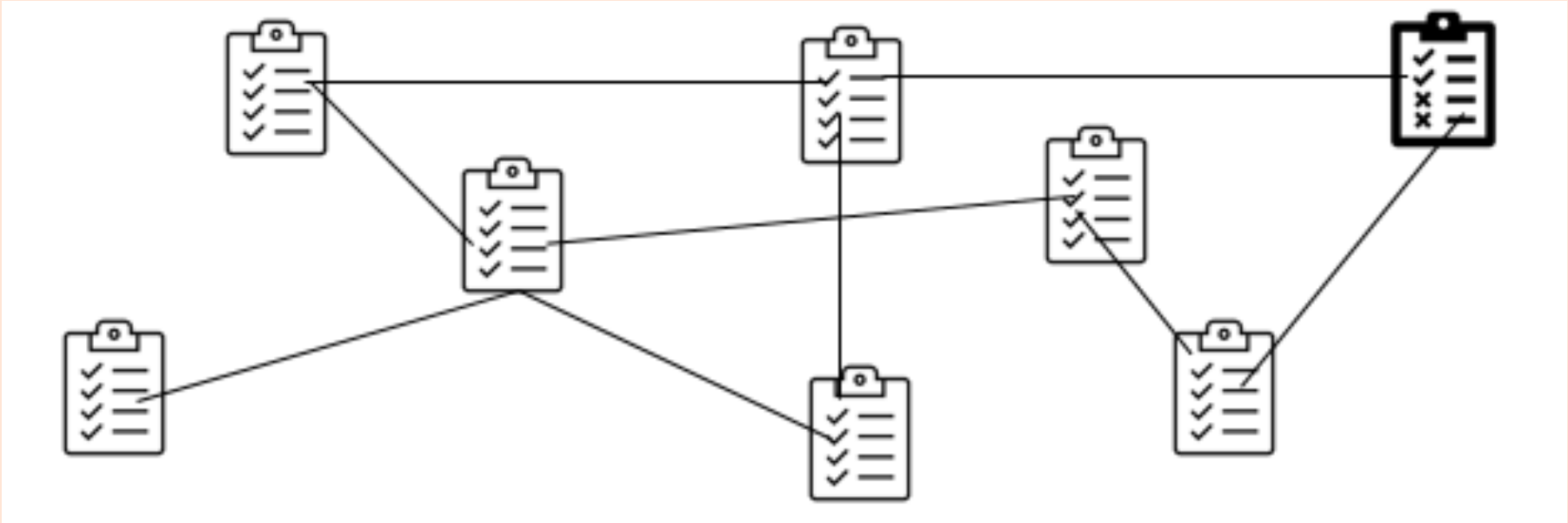
- **Decentralization**: no need for a trusted third party or intermediary to validate transactions.
- **Transparency and trust**: because ledgers are shared and everyone can see what are on it.
- **Immutability**: once data has been written to the blockchain, it is extremely difficult to change it.
- **High availability**: data is replicated on every node, the system becomes HA.
- **Highly secure**
- **Faster dealing**: does not require a lengthy process of verification, reconciliation and clearance.

十分调

- **Cost saving**: eliminate the middle man/trusted party
- **Simplification**: adaptable in diff industries to simplify their current architecture.

Consensus 一致

- Decentralized ledgers need to have consistent data.
- Imagine an attacker in a blockchain attempts to erase a transaction from its own ledger and convince other node that this transaction does not exist.



Consensus

Consensus is the backbone of a blockchain. It provides decentralization control through an optional process known as **mining**.
Different consensus algorithms are used in different types of blockchain.

- **Traditional Byzantine Fault Tolerance (BFT)-based**: replies on a simple scheme of nodes that are publisher-signed messages. Eventually when a certain number of messages are received, the agreement is reached. (e.g. Paxos)
- **Leader election-based consensus mechanism**: nodes competes in a lottery. 抽彩 The nodes first able to broadcast the "winning ticket" is the leader of that round. The leader will announcement the update in the ledge of that round.
  - Commonly seen in public blockchain such as bitcoin (Proof of Work **PoW**).

💡 Does voting work? Think about the *membership* issue.

why

Using Bitcoin as an Example

bitcoin

Bitcoin - a bit history

Concept proposed by a cryptographer David Chaum in 1982 as the concept of e-cash.

- Use blind signatures to build untraceable digital currency. 货币
- Still require a centralized authority.

Bitcoin as introduced in 2008 by Satoshi Nakamoto (believed to be a fake name) through a paper called, *Bitcoin: A Peer-to-Peer Electronic Cash System*.

- First purely p2p electronic cash that does not need a intermediary bank.
- Use modern cryptography tools like hash function, public key, digital signature.

In 2010, programmer Laszlo Hanyecz bought two Papa John's pizzas for ฿10,000. SEC recently announced that digital tokens fall under the category of security.

?

Bitcoin value

The smallest token of a bitcoin unit is a Satoshi (SAT).
As at 2020 April, 1 BTC worths 54,600 HKD
The total supply of Bitcoin is: ฿21,000,000 (sorry, no QE even for covid-19)

DENOMINATION	ABBREVIATION	FAMILIAR NAME	VALUE IN BTC
Satoshi	SAT	Satoshi	0.00000001 BTC
Microbit	µBTC (uBTC)	Microbitcoin or Bit	0.000001 BTC
Millibit	mBTC	Millibitcoin	0.001 BTC
Centibit	cBTC	Centibitcoin	0.01 BTC
Decibit	dBTC	Decibitcoin	0.1 BTC
Bitcoin	BTC	Bitcoin	1 BTC
DecaBit	daBTC	Decabitcoin	10 BTC
Hectobit	hBTC	Hectobitcoin	100 BTC
Kilobit	kBTC	Kilobitcoin	1000 BTC
Megabit	MBTC	Megabitcoin	1000000 BTC

bitcoin denominations

No account concept

In bitcoin network, there is no such physical storage of "account" and "balance".
Only transactions are recorded from ledger.
The compute someone's account balance, it simply recomputes all transactions related to that account from day 1.

Transaction	Kevin's Balance
init	0
Arron pays Kevin 50	50
Kevin pays Brian 10	40
Balance	40

How transaction is made

- Every user in the bitcoin networks has a ECC public key/private key (no signed certificate is needed). A bitcoin **address** is calculated by hashing the public key.
- A transaction is made by specifying the amount and bitcoin address. Then the user/sender produce **digital signature** of the transaction using its private key. The signed transaction is then broadcasted to the Bitcoin network.
- All nodes, especially **miners**, will listen to transactions and include this transaction in the next block for "commit". ?
- When the mining round begins, all miners are *competing for the lottery*. Whoever wins, will announce its winning tickets and the transactions he has prepared for this block. The winning miner, will receive some rewards.

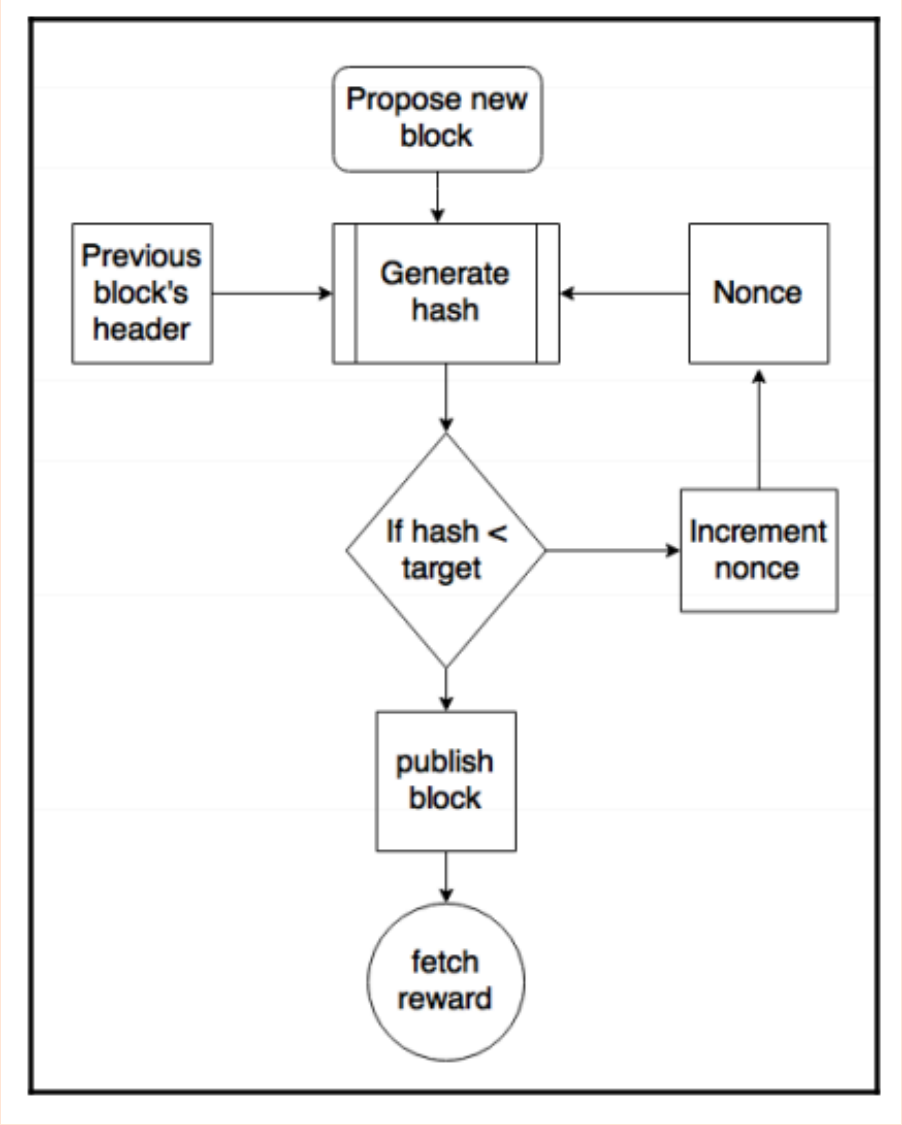
Public key func

① use Public key to encry

② in DS.

Task of a miner

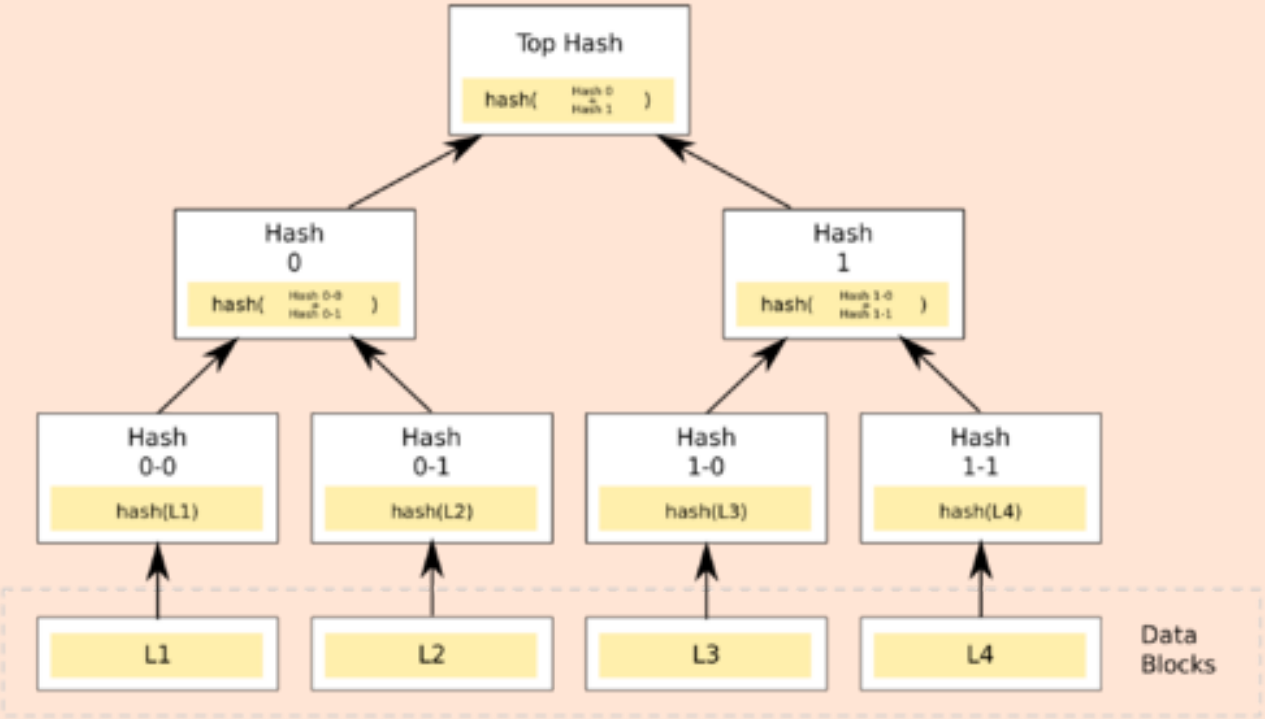
- Fetch previous block headers from the network
- Verify the signatures and transactions
- Verify the previous block lottery 抽签、彩券.
- Assemble the set of transactions received into a block 召集
- Compute the double hash of the previous block's header
- Announce the PoW to the network and fetch the reward



Merkle Tree

- The main use of a Merkle tree is to make sure that data blocks received from other peers in a peer-to-peer network are received undamaged and unaltered, and even to check that the other peers do not lie and send fake blocks.
- Each arrow indicates the input of a hash function. The top hash is used to verify if the hash are unmodified.

未改变的



ref: bitcoinwiki.org

Competing for the lottery

- Proof of Work (PoW) is a proof that enough computational resources have been spent in order to build a valid block.
- Recall that the impossibility to invert a cryptographic function. $H^{-1}(y)$ is impossible.

$Pr(H(x) < 2^{246})$

ten bits to be all zero.

- PoW requires all miners to computes:

$$H(N||P||\boxed{T_1||T_2||T_3||T_4||...T_x}) < \epsilon,$$

  - Say, ϵ has the first 10-bits = 0. P is the previous block hash. ϵ is getting smaller and smaller when times go on.
- Once a miner/cluster found N, it announces N and the set of transactions to everyone.

$|H(\cdot)| = \underbrace{10||00||0011 \cdots}_{256} = 8+$

PoW

When a miner declares a *found*, all other miners verify the set of transactions and the announced N by computing the same hash function.

Other miners will reject either when:

1. A transaction T_i in the transaction sets is invalid; or
2. The hash is invalid

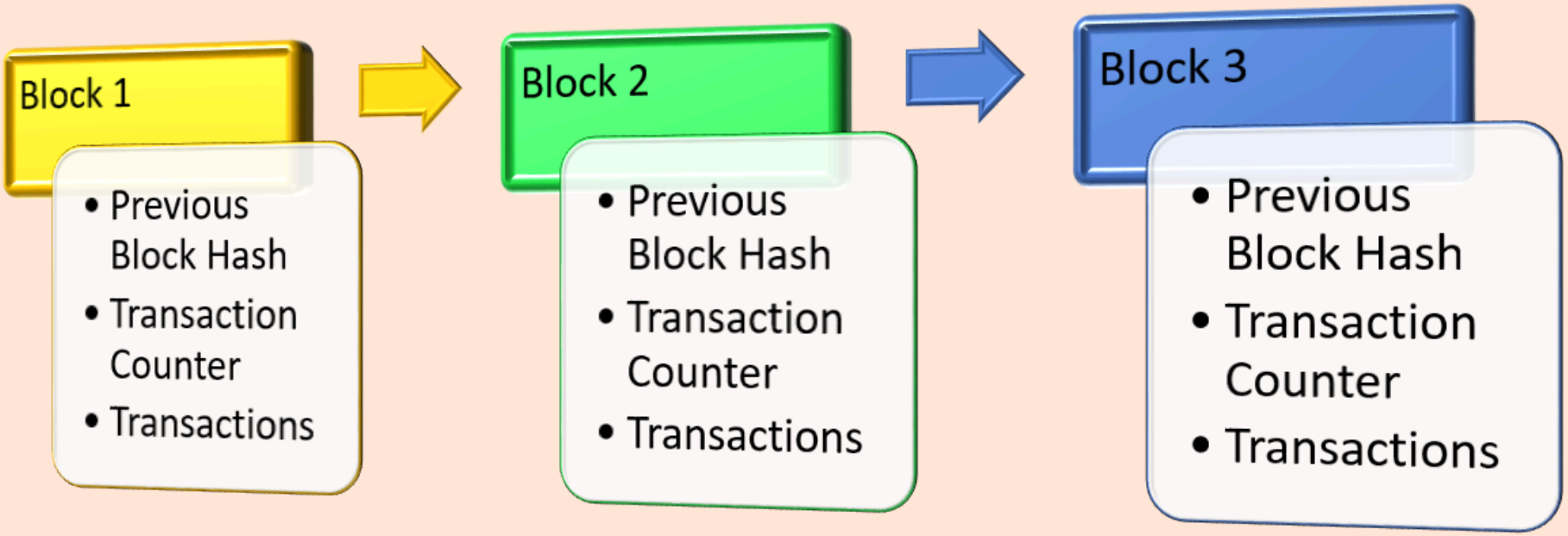
If a transaction is missing, miners will try to add it back in the next round.

- PoW assures that a simple **Sybil attack** cannot be made by an attacker.
  - Because the probability for an attacker to announce a block is bounded by the probability for him to find a block!

Prevented : not voted

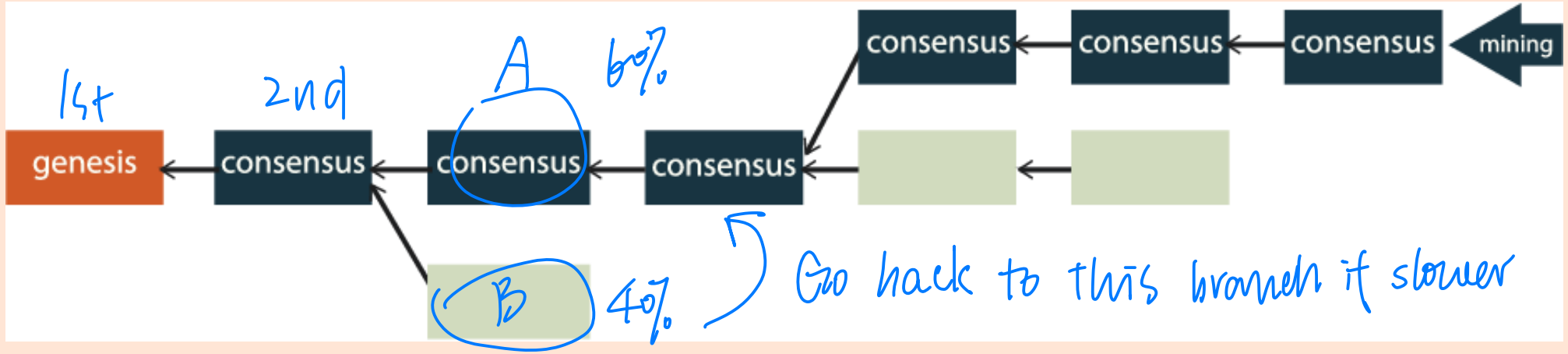
Blockchaining

Private key lost → Account lost.



Two winners?

%: computation power



- It is possible that before a miners can announce his result to all other miners, a second N is produced. In this case, some machine will run on branch 1, some machines will run on branch 2.
- In the next round, if branch 2's computer win the lottery, it will announce the result and all miners (both branch 1 & 2) will reach a consensus.

Kroll, J.A., Davey, I.C., & Felten, E.W. (2013). The Economics of Bitcoin Mining, or Bitcoin in the Presence of Adversaries.

Where the first coins comes from?

- A coinbase transaction or generation transaction is always created by a miner and is the first transaction in a block.
- Since 2009, a successful mining will be given to 50 bitcoins. (A transaction of *System* pays *Miner A* $50). Everyday 144 blocks or rounds are mined.
- After every 210,000 blocks, the reward halves to control inflation and limit the supply of bitcoins. In 12/6/2020, each reward will be reduced down to 6.25 BTC.
- After all bitcoins runs out (no more system rewards), miner will be rewarded by *service charge only* (transaction fee).

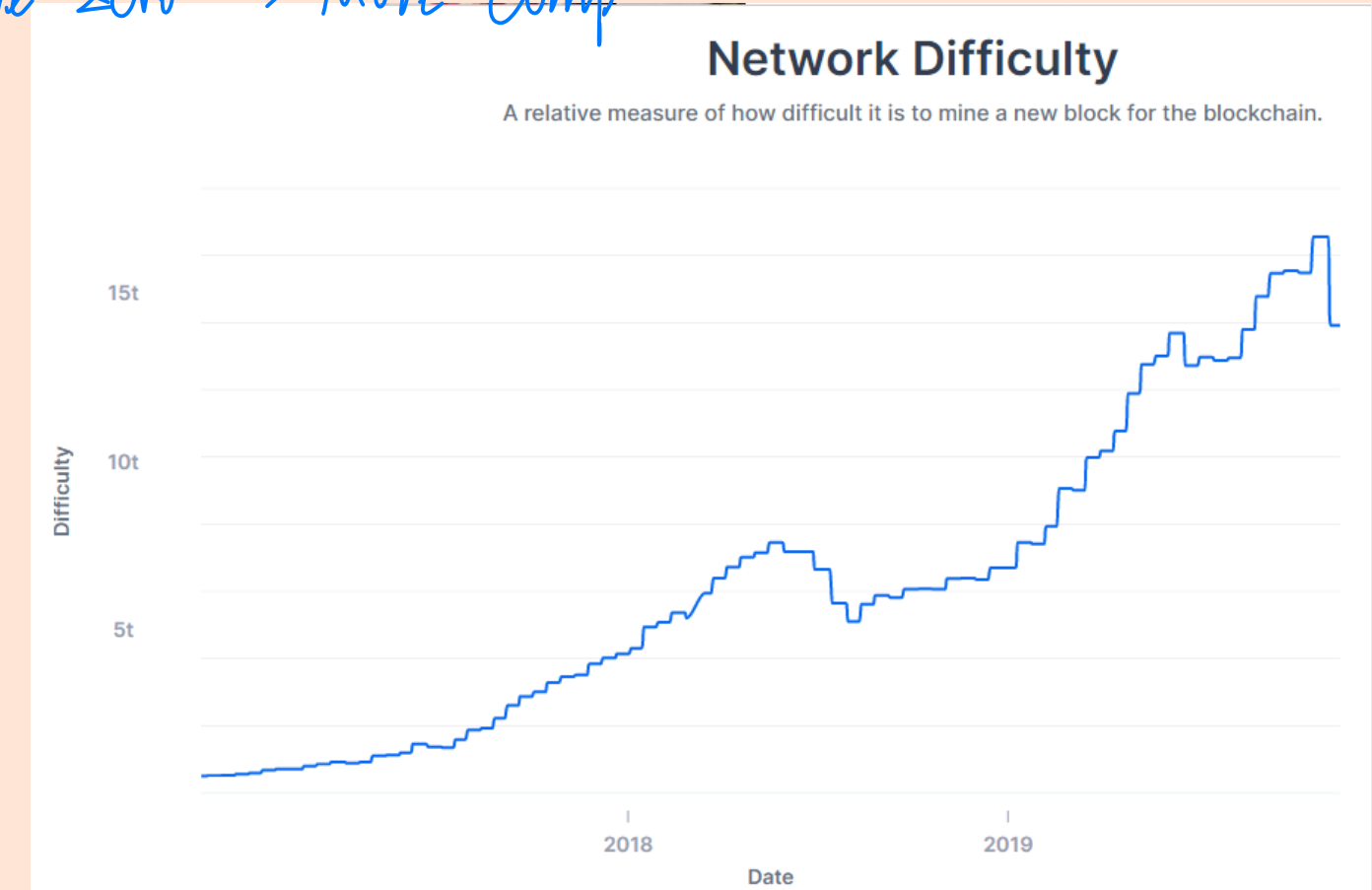
通胀 涨价

?

Network Difficulty

More zero → More comp

- Network Difficulty is a relative measurement of how hard to win the lottery.
- It is calibrated 校准 automatically to maintain the time to be 10 minutes.
- When there are more investment/participants in mining, the PoW is adjusted to be less likely to find the solution.



ref bitcoin.it, blockchain.com

Thievery/lost of private key

- All transaction requires a digital signature, which involve a private key!
- No authority can reclaim the private key for you if it is lost.
- Report showed more than 20% of bitcoin lost due to the lost of private key by end-users.
- Crypto Hunter - offer forensics service in lost and found from computer/tracking scams 鉴定 诈骗.
- Crypto Hypnotists - help you recall your memory

https://www.wsj.com/articles/a-fifth-of-all-bitcoin-is-missing-these-crypto-hunters-can-help-1530798731

Security Problem of Bitcoin

Sybil Attacks

- With PoW, Sybil attacks (by creating a large number of identity), does not give any advantage in mining.
- Yet, if someone has the dominant computation power (51%) on earth, he can manipulate the ledger.

操作

恶意的

In May of 2018, Bitcoin Gold, at the time the 26th-largest cryptocurrency, suffered a 51% attack. The malicious actor or actors controlled a vast amount of Bitcoin Gold's hash power, such that even with Bitcoin Gold repeatedly attempting to raise the exchange thresholds, the attackers were able to double-spend for several days, eventually stealing more than $18 million worth of Bitcoin Gold.

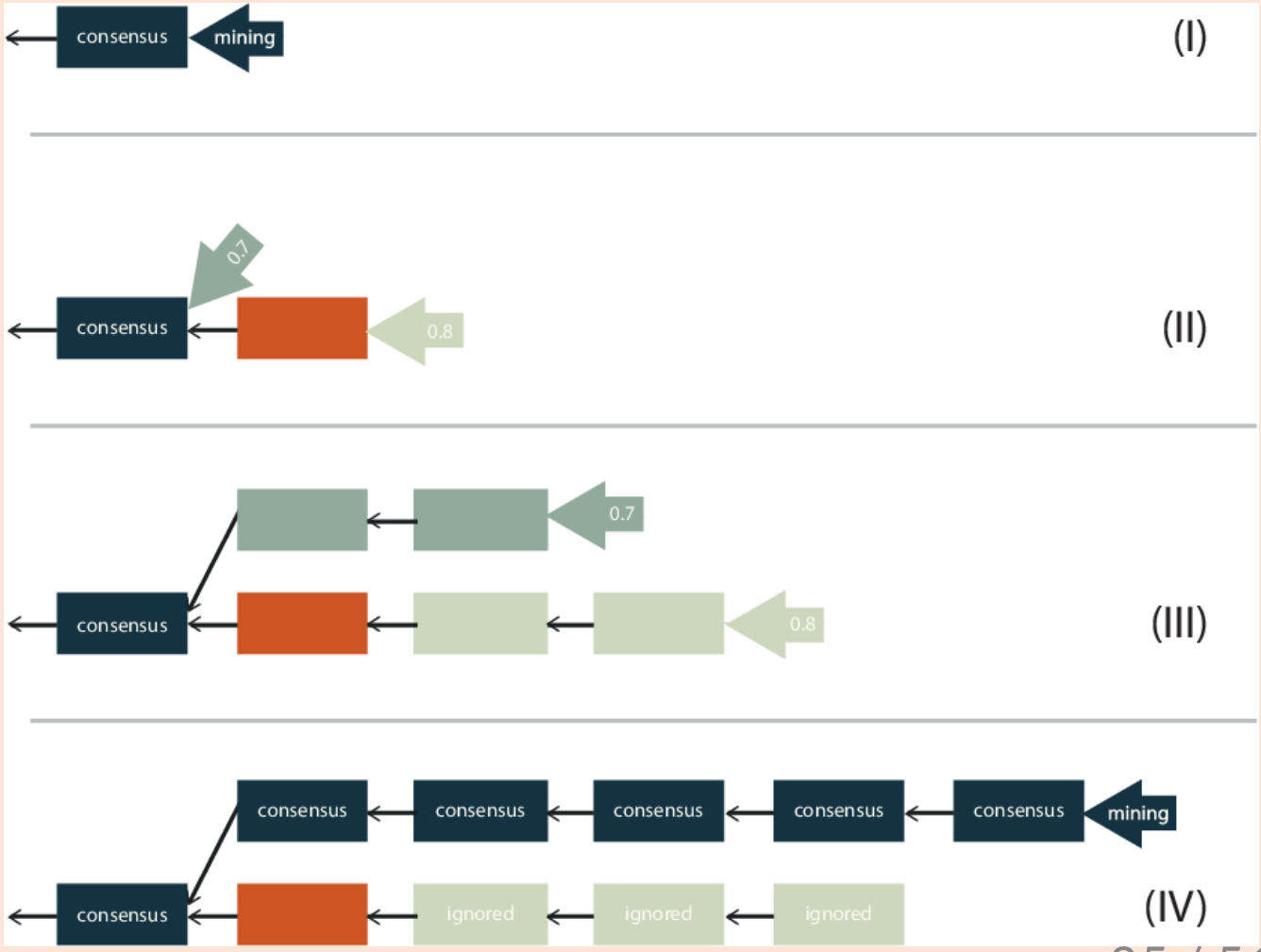
入侵

https://www.investopedia.com/terms/1/51-attack.asp

Security Problem of Bitcoin

Selfish Mining

- Research shows that miners can earn more bitcoins by hiding newly-generated blocks from the main blockchain and creating a separate fork.
- Sharing the new block to within their own network only.



Security Problem of Bitcoin

Race attack (double spending)

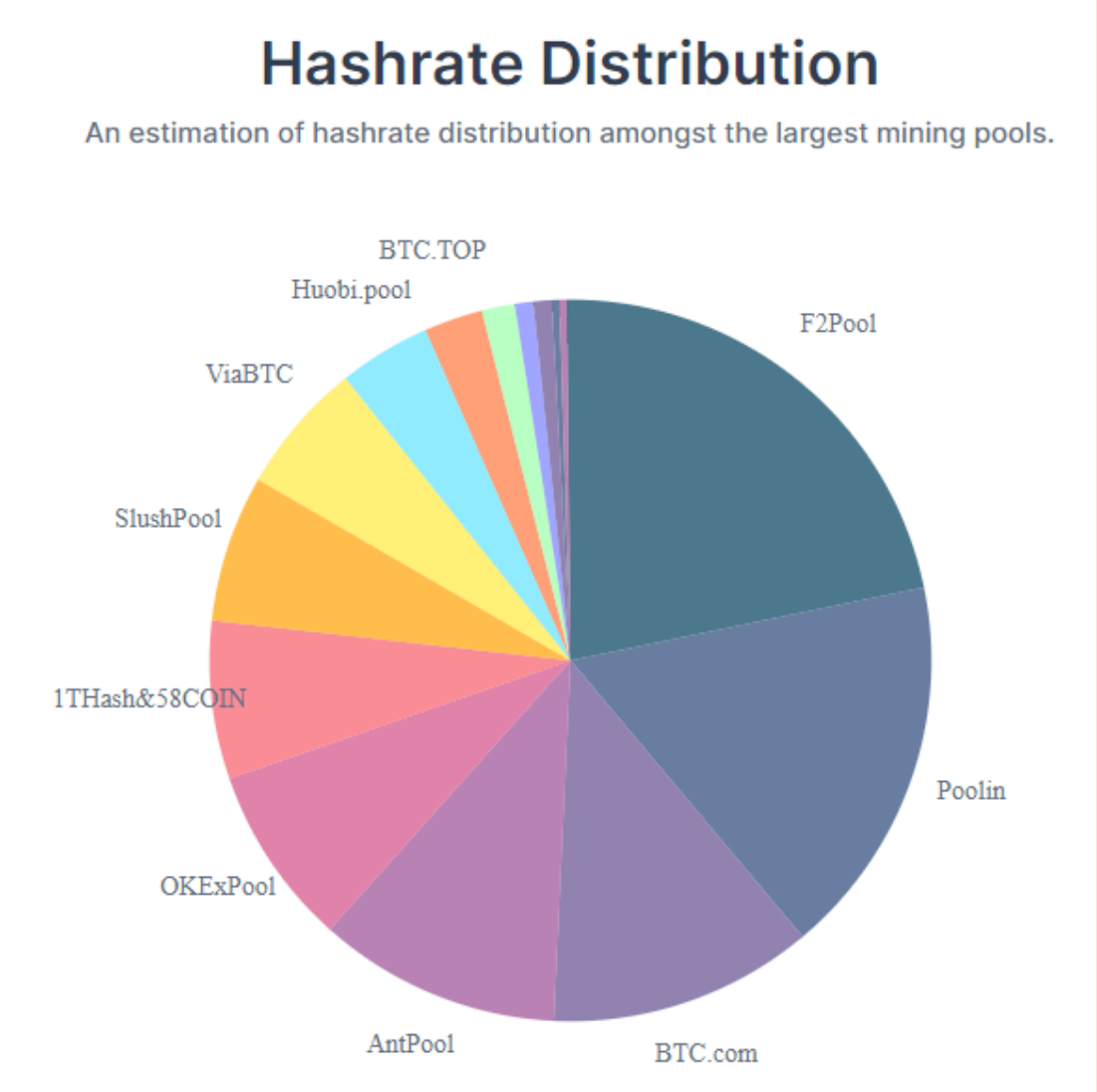
- An attacker attempts to send the same coin to two different vendors (also submit to two different miners)
- The vendor may deliver product to the attackers without waiting for the completion of the mining process.
- But very soon the vendor may see the transaction will be rejected because of double spending.

?

Mining Hardware

- Mobile phone - not really useful due to poor computation power, battery restriction, non dedicate
- CPU - convenient for everyone, useful in the early days
- GPU - GPU support faster and parallelized calculations. Easier to O/C.
- FPGA - Field Programmable Gate Array is usually used for prototype 原型 hardware. It "creates" a chipset that dedicate for mining from software.
- ASICs - Application Specific Integrated Circuit, manufactured by IC company for mining.

Mining Pool


Hashrate Distribution
An estimation of hashrate distribution amongst the largest mining pools.
BTC.TOP
Huobi.pool
F2Pool
ViaBTC
SlushPool
1THash&58COIN
Poolin
OKExPool
AntPool
BTC.com

Environmental Issues

PoW wastes energy - estimated total electricity consumed by Bitcoin miners are measured in Terawatt, released more than hundred kg of COs per transaction. Environmentalist have raised real concerns about this situation.

https://cbeci.org/mining_map

Smart Contract

If transactions of e-cash can be done over blockchain, can transactions of other things to be done over blockchain too?

Definition from Bashir

> 👩‍🏫 💬 A smart contract is a secure and unstoppable computer program representing an agreement that is automatically executable and enforceable

- A computer program - checks condition and settle transactions
- Unstoppable - a contract cannot be revoked; fault-tolerant;

Examples

Insurance

AXA has launched an insurance product Fizzy that uses smart contract technology to deal with flight delay insurance claims. The smart contract is connected to global air traffic databases so that when an over two hours delay occurs, payment is automatically triggered.

Supply Chain Management

In a supply chain network, once an item reaches the final destinations, the ownership status of the item changes. With smart contracts, everyone in the supply chain can track the location of the item with the help of IoT sensors and smart contracts. If an item is lost during the process, smart contracts can detect its location. Smart contracts can also automate all the routine tasks and payments involved so organizations don't need to send around large amounts of documents as everything is virtual.

example quoted from https://research.aimultiple.com/smart-contracts/

Examples

Copyright

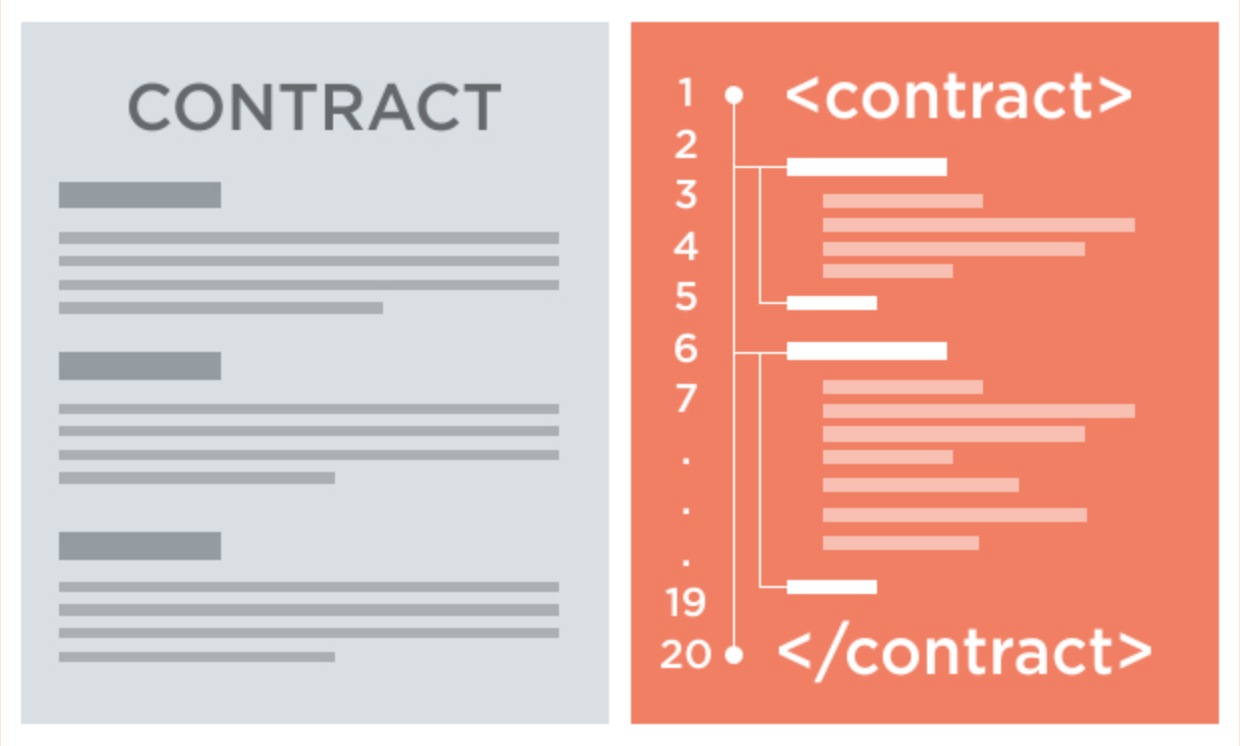
Smart contracts can ensure the royalties to the desired contributor by recording the ownership and other aspects of digital copyright assets such as digital ID or fingerprint on the blockchain.

Property Ownership

Property ownership change contracts can be programmed and can be executed automatically. For example, once the buyer makes the payment to the seller, the smart contract can automatically change ownership of the asset based on the payment information on the blockchain. For instance, Prophy enabled the world's first property transaction using smart contracts in 2017. Their first transaction was a $60,000 apartment in Ukraine.

Automatable Smart Contracts

- In some scenarios smart contracts need not be automatically executable
- Manual human input require
- For example, verification of a medical record might be required by a qualified medical professional.



Smart contracts in a court of law

- A smart contract is different in presentation from traditional legal
- But a court of law does not understand the code.
- How a smart contract can be legally binding?
- How can dispute resolution be implemented within the code?
- How regulatory and compliance requirements are enforced?

Legal Knowledge Interchange Format (LKIF) is designed to represents contract in both human and machine readable language.

Code is Law

- All digital asset (including e-cash) is governed by code
- Contracts are **self-enforcing**
- Contracts are **autonomous**

Distributed Autonomous Organization (DAO)

- Multiple smart contracts interact together form a DAO that automatically execute contract.
- Autonomous governance organization by code only
- Decentralized and cannot be switched off

Smart contracts is deterministic program

- Allow a smart contract to be run by any node on a network and achieve the same result.
- If the result are slightly different, no consensus can be achieved.
- Using random function (e.g. `rand()`) can cause problems.
- A various floating-point operations calculated by various functions in different languages can produce different results and thus can be a problem.
- Some math functions in JavaScript can produce different results for the same input on different browsers.

Oracles

- Programs always require input.
- External input has to be authentic
  - Sales of a book affect the payment to the book author.
  - Stock price of a security product that is required by the contract to release the dividend payments.
- An **Oracle** is a trusted entities that use a secure channel to transfer data to a smart contract.
- Data from an Oracle is digitally signed.

Data comes from:

- Internet-of-Things (IoT) devices
- Centralized source (e.g. reputable weather reporting agency, stock exchange)
- Multiple sources
- Decentralized oracles - data from another blockchain

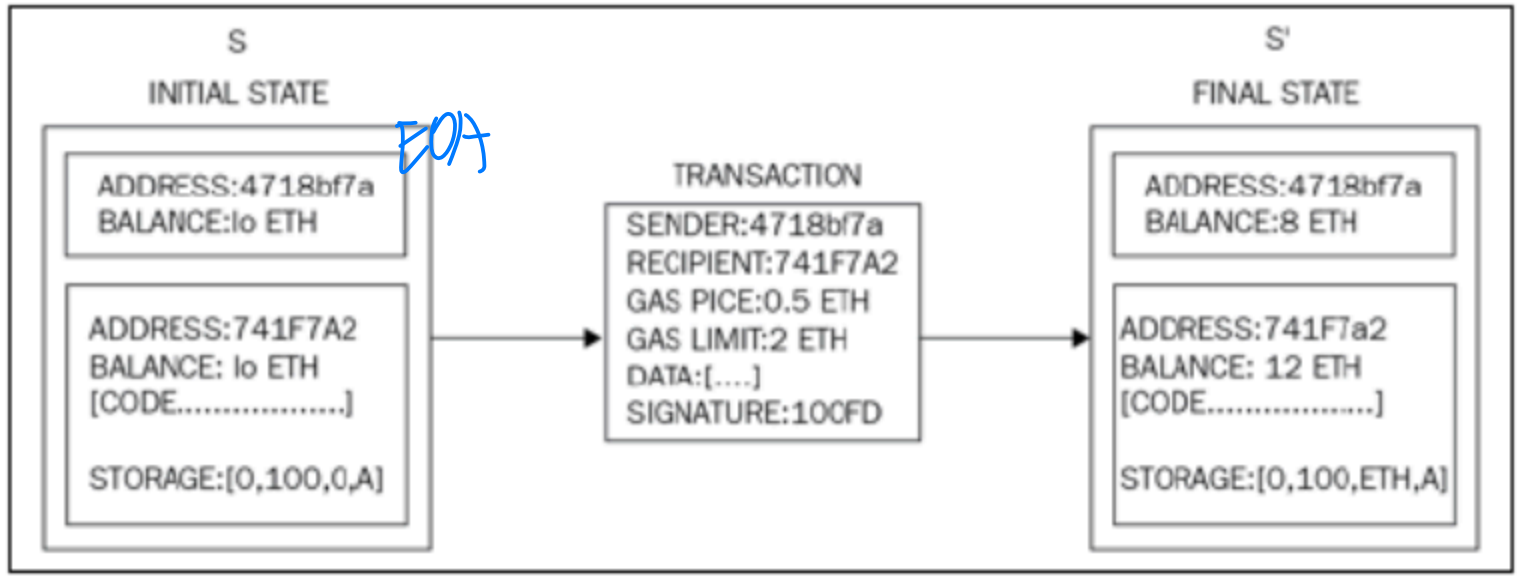
Ethereum

Ethereum (since 2015) is not just the second largest crypto-currency (Ether); it provides a *programmable* transaction on blockchain. It is a transaction driven state machine.

- States / variables are created or updated by the interaction between accounts and transaction execution.

Two kinds of accounts in Ethereum:

- Externally Owned Accounts (EOAs) - similar to bitcoins
- Contract Accounts (CAs) - have code associated with it.



Ethereum State transition function

EOAs

- EOAs has ether balance
- They are capable of sending transactions
- They have no associated code
- They are controlled by private keys
- Accounts contain a key-value store
- They are associated with a human user

CAs

- CAs have Ether balance.
- They have associated code that is kept in memory/storage on the blockchain.
- They can get triggered and execute code in response to a transaction or a message from other contracts. The code is executed by Ethereum Virtual Machine (EVM) by each mining node.
- CAs can maintain their permanent state and can call other contracts.
- CAs contain a key-value store.

Transactions and messages

Transaction are signed by a private key, can be divided into two types:

- **Message call transactions**: Produces a message call that is used to pass message from one contract account to another.
- **Contract creation transactions**: Creates a new contract account that contains some code to run.

Each transaction has the following fields:

- Nonce: a counter that to avoid replay attacks.
- Gas price: the transaction price for you are willing to pay for running this code.
- Gas limit: the maximum amount of gas that can be consumed to execute
- Data: input data of the message call
- Others field including To/Value/Signature

Transactions validation and execution

For example, a crop insurance application that's dependent on an outside weather feed.
A smart contract issued from the company to a farmer: "Pay you $50 if flood".
This will be programmed by a simple `if-then` statement.
When it is flood, the contract will be executed by taking external parameters as a message call transactions.

Gas

- A contract/program is executed with cost.
- Each operation costs some gas.
- A contract is created with a gas limited such that by how many gas the owner is willing to spend to run the contract.
- This also prevent a bad programmed contract that does not stop.

Decentralized Applications - DApp

分别的.

DApps are software programs that can run on their respective blockchains, use an existing established blockchain, or use only the protocols of an existing blockchain.

KYC-Chain

场所

This application provides the facility to manage Know Your Customer (KYC) data securely and conveniently based on smart contracts.

OpenBazaar

This is a decentralized peer-to-peer network that enables commercial activities directly between sellers and buyers instead of relying on a central party, such as eBay and Amazon.

Lazooz

This is the decentralized equivalent of Uber. It allows peer-to-peer ride sharing and users to be incentivized by proof of movement, and they can earn Zooz coins.

激

Other consensus algorithms

The PoW consensus protocol served as a mechanism to provide assurance that a miner had completed the required amount of work to find a block. This also prevents the possibility of Sybil attacks.
Power goes to people who can afford to operate large-scale ASIC farms, it violates the philosophy of decentralization.

Besides, environmental issue!

Proof-of-Stake (PoS) 桩

- Idea: money/stake shows you are not a Sybil clone.
- The probability of being awarded 份额 = b/a where b is the total number of coins a miner has, a is the total coin in the market.

```
Function BlockGen():
    Pack up transactions and prepare a block header context C
    Set up a clock and check for the following condition per clock tick:
        Hash(C|clock_time) < target x stake_value
    return new block;
```

?

The tick of clock is fixed and the clock cannot be changed. The more stake a person has, the higher chance he will be awarded.

Proof-of-Activity (PoA)

杂交.

- A hybrid PoW-PoS adaptation
- Use the algorithm called Follow-The-Satoshi (FTS)

SAT

?

1. At the beginning of block k, an empty block header EB_k is generated and propagated across the network.
2. Find the owners/miners of N Satoshi.
3. The N miners verify the block and digitally signed on the new block.
4. The N miners receives reward.

The more stake a miner has, the higher chance he will be awarded.

Proof-of-Burn

- Destroys a certain number of bitcoins to get equivalent coins.
- Award goes to who burn more coins.
- The award make sense only if the award is more than the coin burnt
- Can be used when starting up a new coin projects as a means to provide a fair initial distribution.

How.

Proof-of-Deposit 放下.

- A fixed number of coins is unspendable for a certain period.
- Miners to perform mining at the cost of freezing a certain number of coins for some time. ?
- Miners with shorter stake theoretically will be able to award as well.

Case Study

[20%] In a city, the second hand car market has the following problems:

1. Buyers do not want to purchase used car in the market because the car owner will “adjust the meter” to modify the distance that the car has run. The more kilometers a car has run, the lower value should the car has.
2. Car owners or agents always claim the used car as “previously owned by a female driver” or “not involved in any major accidents”. But these claims cannot be easily verified.
3. Despite the fact that cars are required to have an annual check by an authentic garage, the annual check report of a used car is not published and buyers cannot know the past conditions of the car.
4. Car owners with little knowledge of the second hand car market always sell their car at a very low price to agents since there is no open and authentic trading data for car owners’ reference.

Case Study (con't)

The government is proposing to apply blockchain technology on the second hand car market.

1. Please suggest how blockchain can be applied in this context.
2. Explain how these problems can be resolved after using blockchain.

You may state any reasonable assumption in answering this question.